

Network Administration and Information Security – Lecture 01

Ms. F. Nkosi, CISA| CEH

Course overview

- To equip students with knowledge and skills in the network administration and information security.

ASSESMENT GUIDELINES

Continuous assessment	**40%**
Final examination	**60%**

LEARNING OUTCOMES

By the end of this course

- Describe the principles of network administration and information security
- Explain the concepts of information security.
- Draft security policy
- Describe network vulnerabilities
- Explain encryption techniques

RECOMMENDED TEXTS

- **PRESCRIBED TEXTS**
- Burgess, M. (2004). *Principles of Network and System Administration* (2nd ed.). John Wiley & Sons Inc.
- Stallings, W. (2017). *Cryptography and Network Security: Principles and Practice*. (7th ed.). Pearson Education Limited.
- **RECOMMENDED TEXTS:**
- Stallings, W. (2011). *Network Security Essentials: Applications and Standards* (4th ed.). Pearson Education, Inc.
- Rainer, R., Kelly, Jr., Turban, E., Potter, R.E. (2007). *Introduction to information systems : supporting and transforming business*. Hoboken, NJ: Wiley.
- Schneier, B. (1996). *Applied cryptography* (2nded.). New York: Wiley.
- Canavan, E.J. (2012). *Fundamentals of Network Security*. Artech House, Boston: London.
- Salomon, D. (2006). *Foundations of Computer Security.* Springer-Verlag: London Limited.
- Peltier, T. R., Peltier, J., & Blackley, J. (2005). *Information Security Fundamentals*. Auerbach publications: London

Activity

- How would you define Network security?
- What are the threats/ Vulnerabilities /attacks that can happen on a network

IT Security

- IT security is the protection of computer systems and networks from information disclosure, theft of or damage to their hardware, software, or electronic data, as well as from the disruption or misdirection of the services they provide.
- IT security performs four important functions for an organization:
  - Protects the organization’s ability to function
  - Enables the safe operation of applications implemented on the organization’s IT systems
  - Protects the data the organization collects and uses
  - Safeguards the technology assets in use at the organization

WHAT IS NETWORK SECURITY

- Network security is defined as: A set of rules and configurations designed to protect the integrity, confidentiality and accessibility of computer networks and data using both software and hardware technologies.

- “Network security is the process of taking physical and software preventative measures to protect the underlying networking infrastructure from unauthorized access, misuse, malfunction, modification, destruction, or improper disclosure, thereby creating a secure platform for computers, users, and programs to perform their permitted critical functions within a secure environment”.(scoonline)



CIA TRIAD

- The primary goal of network security are Confidentiality, Integrity, and Availability.

Confidentiality

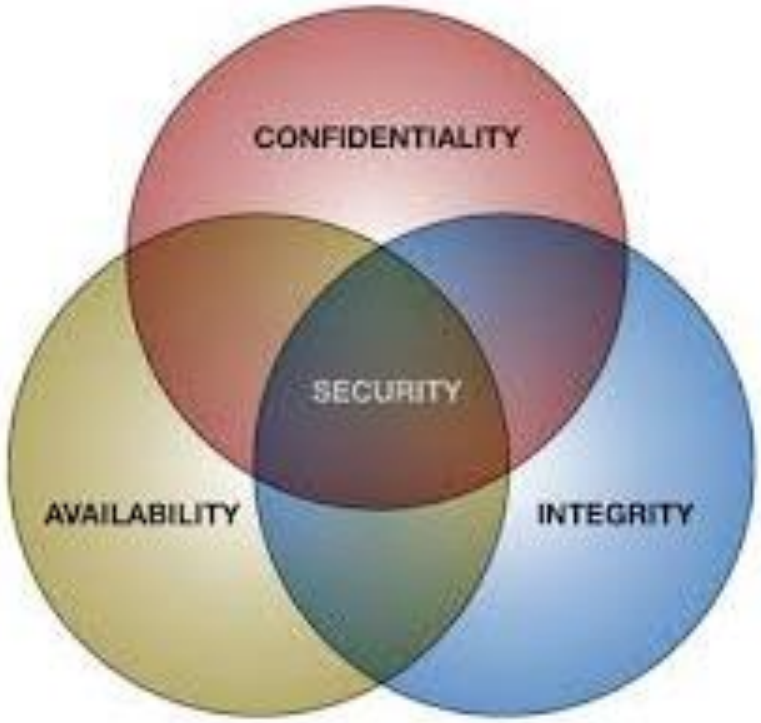
- Assurance that information is shared only among authorized persons or organizations.

Integrity

- Assurance that the information is authentic and complete.
- Maintaining and assuring the accuracy and consistency of data over its entire life-cycle.

Availability.

- Assurance that the systems responsible for delivering, storing and processing information are accessible when needed, by those who need them.



Other Security Services

- **Authentication:** The assurance that the communicating entity is the one it claims to be
- **Non-Repudiation:** Provides protection against denial by one of the entities involved in a communication of having participated in all/part of the communication
- **Privacy:** Ensuring that individuals maintain the right to control what information about them is collected, how it is used , who has it, who maintains it and how it is used.
- **Access Control:** The prevention of unauthorized use of a resource
  - who can have access to a resource,
  - under what conditions access can occur,
  - what those accessing the resource are allowed to do

Vulnerabilities

- A **vulnerability** is a weakness which can be exploited by a threat actor, such as an attacker, to cross privilege boundaries (i.e. perform unauthorized actions) within a computer system.
- Vulnerabilities are classified according to the asset class they are related to:-
  - **Hardware:-** Susceptibility to humidity/dust ; Unprotected storage, Over-heating.
  - **Software:-** Insufficient testing; insecure coding; lack of audit trail; Design flaw.
  - **Network:-** Unprotected communication lines; Insecure network architecture.
  - **Personnel:-** **I**nadequate recruiting process; Inadequate security awareness; insider threat
  - **Physical site:-** **A**rea subject to natural disasters (e.g. flood,earthquake); interruption to power source
  - **Organizational:- L**ack of regular audits; lack of continuity plans;

Threats

- **A threat** is a potential negative action or event facilitated by a vulnerability that results in an unwanted impact to a computer system or application.
- *Any circumstance or event with the potential to adversely impact an IS through unauthorized access, destruction, disclosure, modification of data, and/or denial of service.*
- A **countermeasure** is any step you take to ward off a threat to protect user, data, or computer from harm.
- Various Security threats:-
  - **Users:-** Identity Theft; Loss of Privacy; Exposure to Spam; Physical Injuries.
  - **Hardware:-** Power-related problems; theft; vandalism; and natural disasters.
  - **Data:- M**alwares; Hacking; Cybercrime; and Cyber-terrorism.

Activity



Company B’s system allows users to use weak passwords and does not enforce change of default passwords?

In Company B’s case What would be the:

- Vulnerability?
- Threat-?
- Risk-?

Answers – Weak Password

- **Vulnerability---**password is vulnerable for dictionary or exhaustive key attacks
- **Threat---**An intruder can exploit the password weakness to break into the system
- **Risk---**the resources within the system are prone for illegal access/modify/damage by the intruder.

Answers –Password change not enforced

- **Vulnerability---**default passwords can be used by external people to access a device or software
- **Threat---**An intruder can attempt to login into the system using default passwords
- **Risk---**Attackers can easily identify default passwords of devices and software's and can gain access to computer systems and

Attacks

- An attack is the deliberate act that exploits vulnerability
- It is accomplished by a threat-agent to damage or steal an organization’s information or physical asset
  - An exploit is a technique to compromise a system
  - A vulnerability is an identified weakness of a controlled system whose controls are not present or are no longer effective
  - An attack is then the use of an exploit to achieve the compromise of a controlled system



Types of Computer Attacks

- **Back Doors** - Using a known or previously unknown and newly discovered access mechanism, an attacker can gain access to a system or network resource
- **Password Crack** - Attempting to reverse calculate a password
- **Brute Force** - The application of computing and network resources to try every possible combination of options of a password
- **Dictionary** - The dictionary password attack narrows the field by selecting specific accounts to attack and uses a list of commonly used passwords (the dictionary) to guide guesses

Computer Attacks

- Attacks on computer systems break-in to destroy information break-in to steal information blocking to operate properly malicious software wide spectrum of problems
- Source of attacks
  - Insiders – Mostly employees whose actions may knowingly or unknowingly expose your computer systems to attacks. i.e plugging an infected flash disk on a computer
  - Outsiders – hackers

Threats to Information Security

Categories of threat	Examples
1. Acts of human error or failure	Accidents, employee mistakes
2. Compromises to intellectual property	Piracy, copyright infringement
3. Deliberate acts of espionage or trespass	Unauthorized access and/or data collection
4. Deliberate acts of information extortion	Blackmail of information disclosure
5. Deliberate acts of sabotage or vandalism	Destruction of systems or information
6. Deliberate acts of theft	Illegal confiscation of equipment or information
7. Deliberate software attacks	Viruses, worms, macros, denial-of-service
8. Forces of nature	Fire, flood, earthquake, lightning
9. Deviations in quality of service from service providers	Power and WAN service issues
10. Technical hardware failures or errors	Equipment failure
11. Technical software failures or errors	Bugs, code problems, unknown loopholes
12. Technological obsolescence	Antiquated or outdated technologies

Security Attacks

1. **Passive attacks:** Attempts to learn or make use of system resources but does not affect system resources.
   - Listening to telephone conversations, traffic analysis
   - Difficult to detect
   - The names of some passive attacks are traffic analysis, Eavesdropping, and Monitoring
2. **Active attacks:** Attempts to alter System resources or affect their operations.
   - Masquerade where one entity pretends to be a different entity, denial of service attack
     - Active attacks are very difficult to prevent

COMMON NETWORK THREATS

- Threats to network security are continually changing.
- They evolve as developments in operating systems, application software and communication protocols create new opportunities for attack.
- For the purposes of this class will look into the following network threats:
  1. Malware
  2. Brute force attacks
  3. Packet sniffing
  4. Denial of service attacks
  5. Man in the middle attacks
  6. Social Engineering
  7. Message modification
  8. Masquerade attacks

COMMON NETWORK THREATS

Malware

- Malware is a code or software designed to damage, disrupt, steal, or inflict some other ‘bad’ or illegitimate action on data, hosts, or networks.
- The three most common types of malware are:
  - Virus
  - Worm
  - Trojan horse.



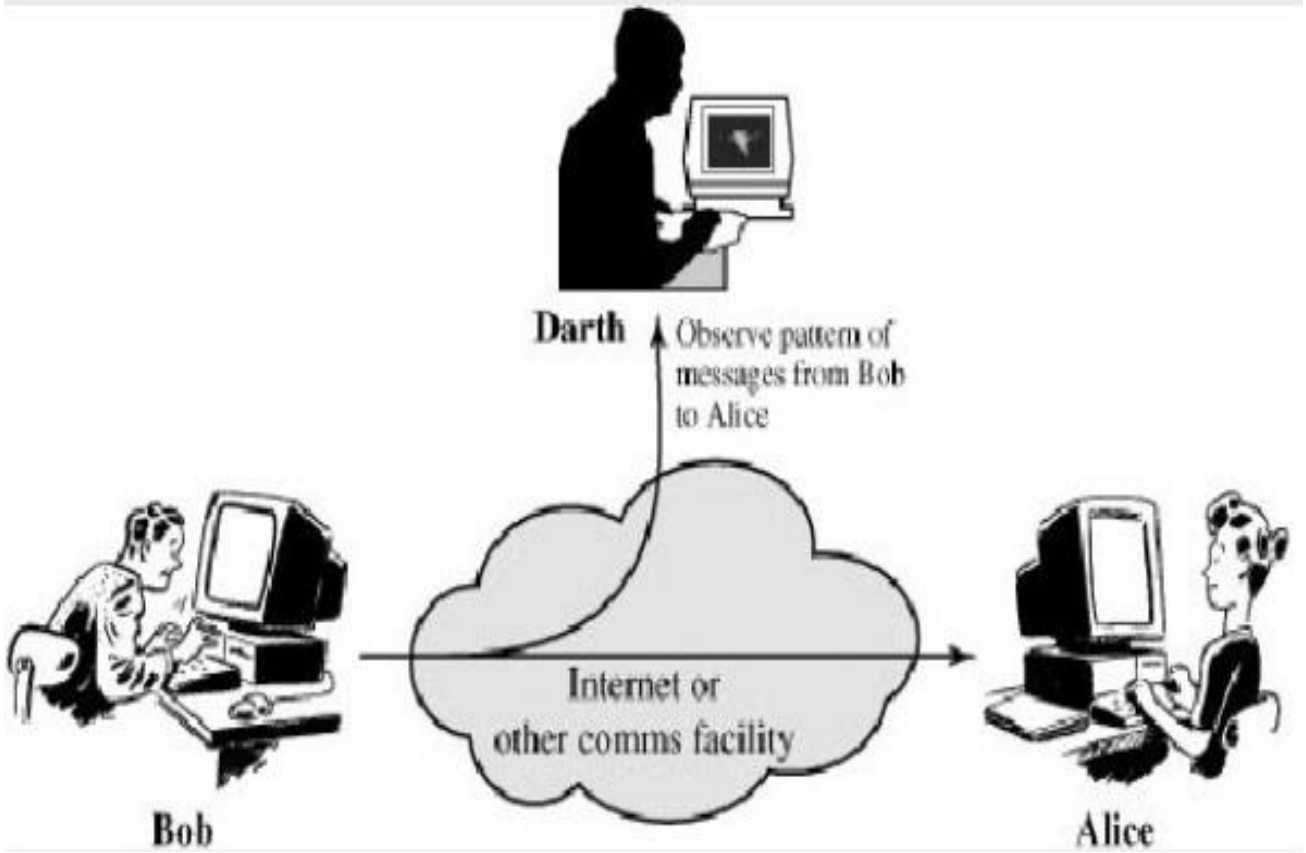
COMMON NETWORK THREATS

A virus is a type of malware that spreads by inserting a copy of itself into another program.	• After the program is run, viruses spread from one computer to another, thus infecting the computers
Trojan horse malware is a software that appears to be legitimate, but it contains malicious code which exploits the privileges of the user that runs it.	• Trojans are found attached to online games.
Computer worms are similar to viruses because they replicate themselves by independently exploiting vulnerabilities in networks.	• Worms can slow down networks as they spread from system to system. • Worms can run without a host program

COMMON NETWORK THREATS

Traffic analysis

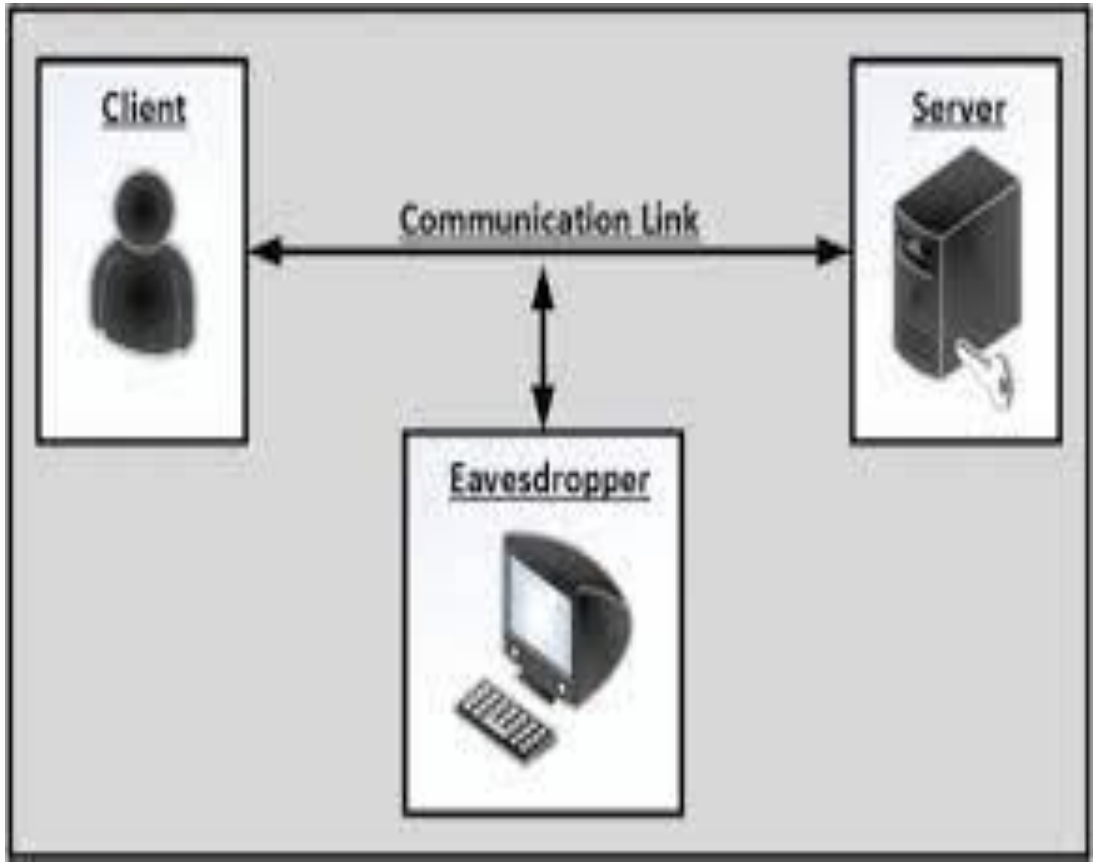
- In the traffic analysis attack, an attacker tries to sense the communication path between the sender and receiver.
- An attacker can found the amount of data which is travel from the route of sender and receiver.
- There is no modification in data by the traffic analysis.



COMMON NETWORK THREATS

Eavesdropping

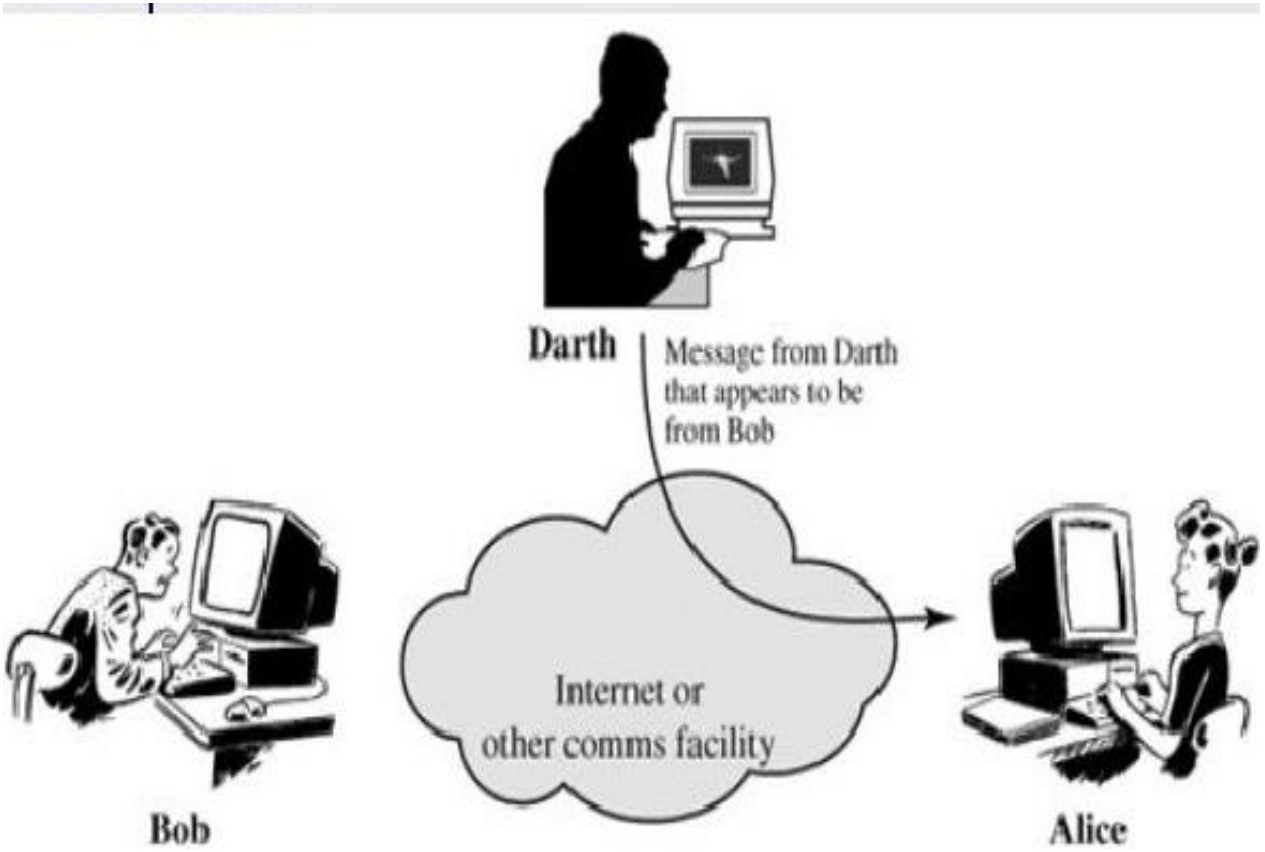
- This is a passive attack, which happens in the mobile ad-hoc network.
- The main aim of this attack is to find out some secret or confidential information from communication.
- This secrete information may be privet or public key of sender or receiver or any secrete data.



COMMON NETWORK THREATS

Masquerade attacks

This is an attack where an entity (usually a computer or a person) taking on a false identity in order to acquire or modify information, and in effect achieve an unwarranted privilege status.

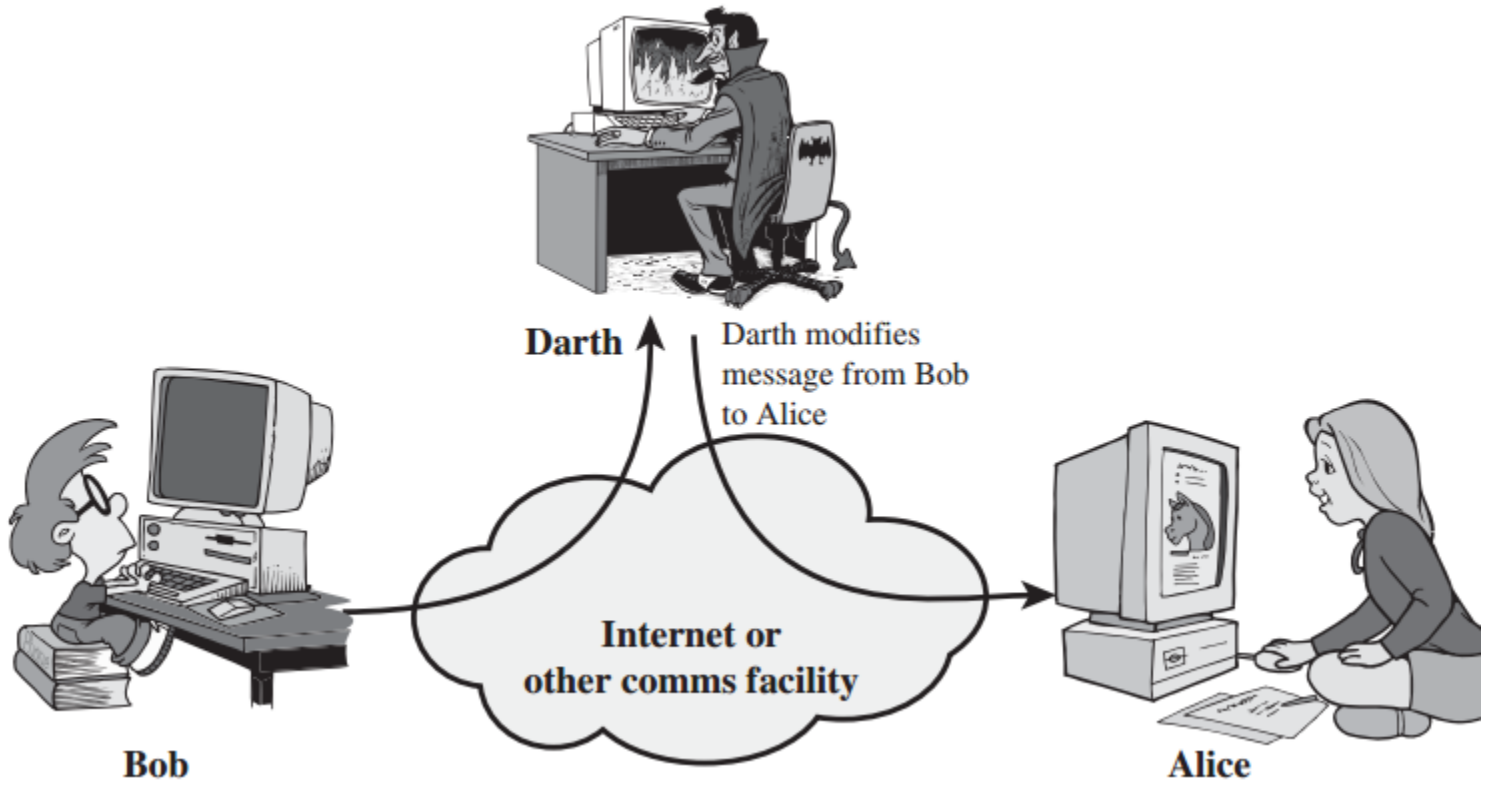


COMMON NETWORK THREATS

Message modification

This attack involve modifying a packet header address for the purpose of directing it to an unintended destination or

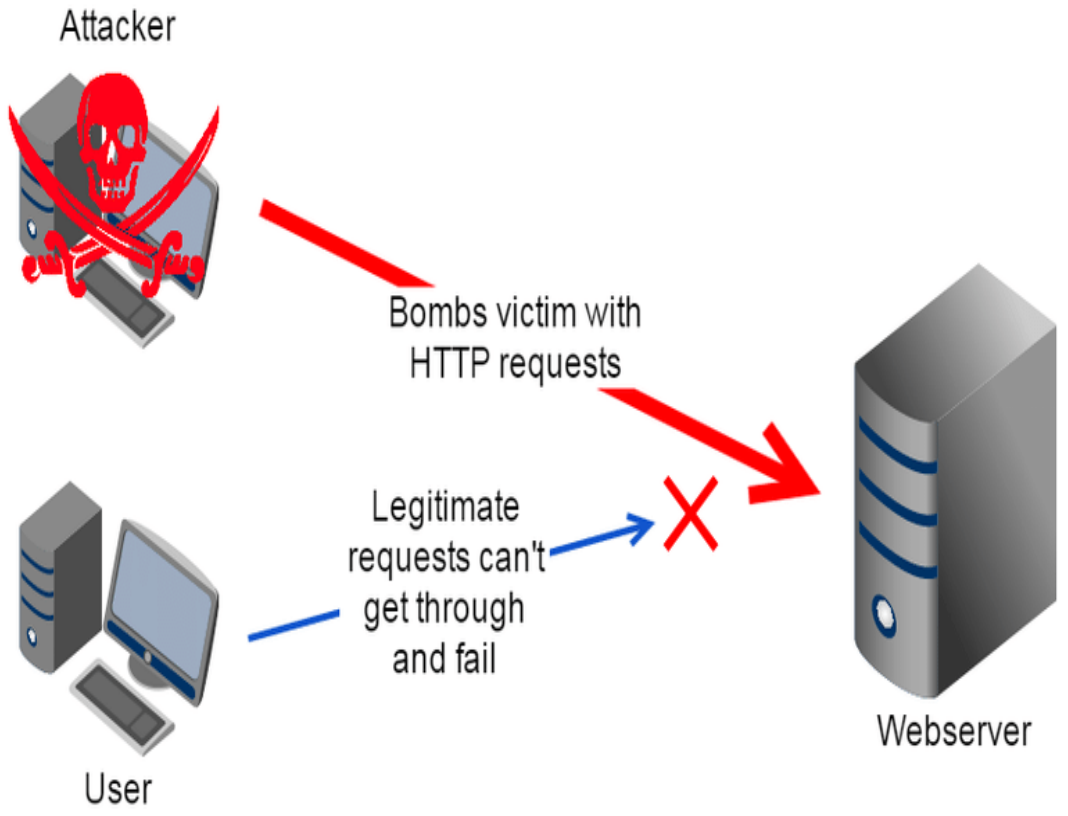
modifying the user data**.**



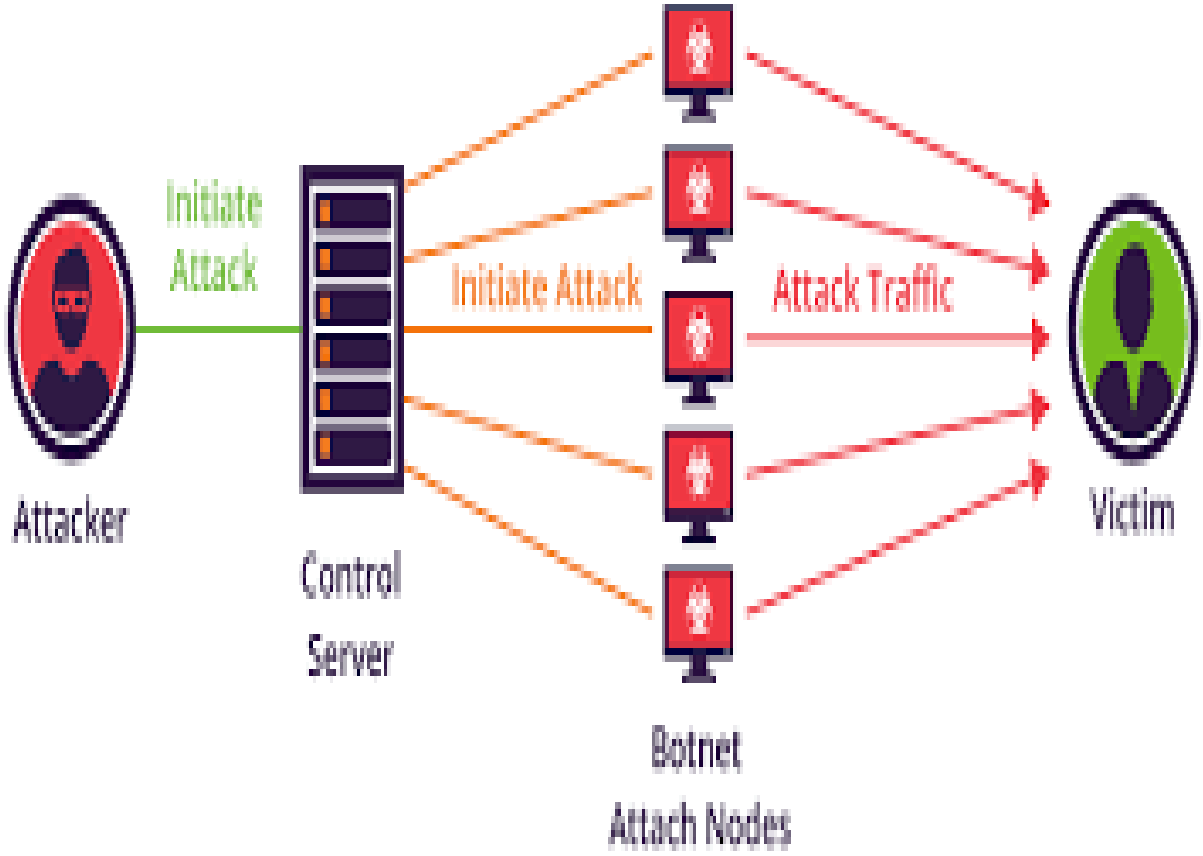
COMMON NETWORK THREATS

Denial-of-Service (DoS) attacks

- In a nutshell, a DoS attack sees an attacker flood a website with an overwhelming amount of traffic, often using ‘bots.’
- As a result, the system crashes and denies access to real users.
- These attacks are growing increasingly popular.
- Hackers can take advantage of vulnerabilities in connected devices and use them to launch Distributed Denial-of-Service (DDoS) attacks.



COMMON NETWORK THREATS



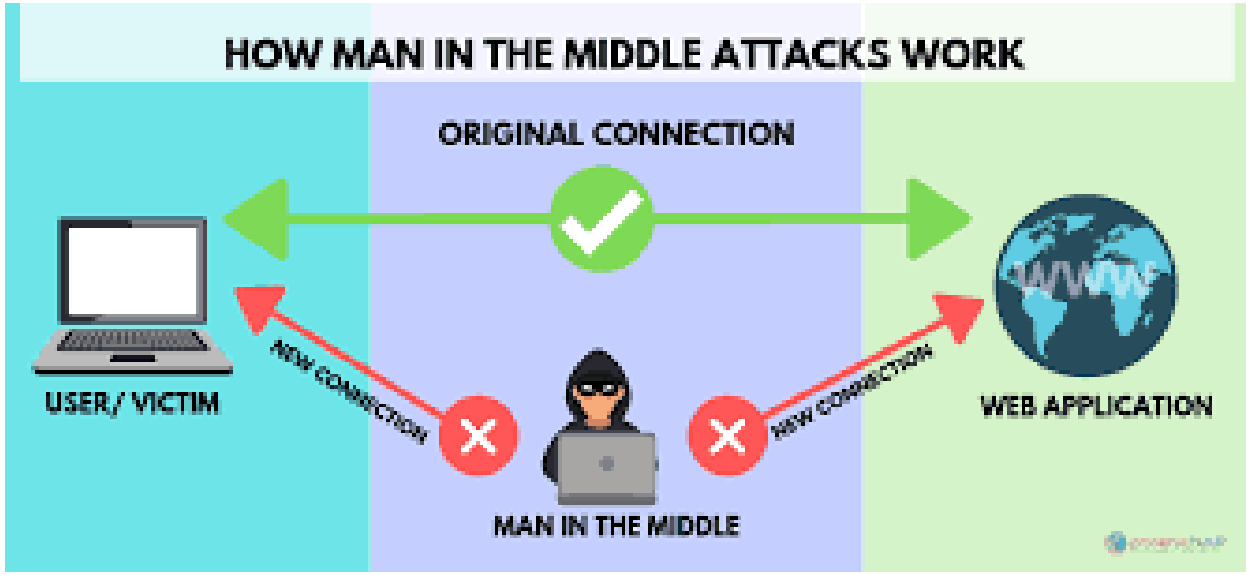
Botnet

- It is a network of private computers which are a victim of malicious software. The attacker controls all the computers on the network without the owner's knowledge.
- Each computer on the network is considered as zombies as they serve the purpose of spreading and infecting a large number of devices or as guided by the attacker.

Common Network Threats

Man-in the Middle attack

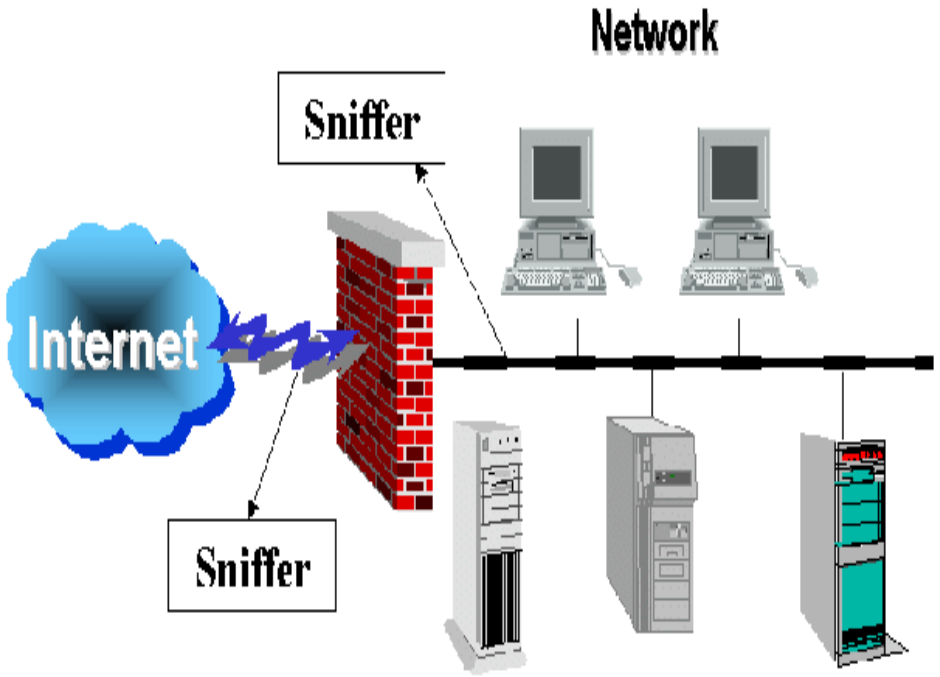
- A man-in-the-middle (MitM) attack is when an attacker intercepts communications between two parties either to secretly eavesdrop or modify traffic traveling between the two.
- Attackers might use MitM attacks to steal login credentials or personal information, spy on the victim, or sabotage communications or corrupt data.



COMMON NETWORK THREATS

Packet Sniffer

- Is a technique of monitoring every packet that crosses the network.
- Packet sniffer records a copy of every packet transmitted.
- These packets can contain confidential information, sensitive and crucial data, trade secrets, etc. which when flew over a packet receiver will get through it.
- The best defense against packet sniffer is cryptography.



COMMON NETWORK THREATS

Social Engineering

- One common example of social engineering that everyone with an email account has likely witnessed is phishing (pronounced like fishing).
- An attacker sends an email message to a targeted group, with the email disguised to make it appear to be from some trusted source.
- If users believe that the email is from that trusted source, they're less likely to worry about giving out their personal information, which can range from usernames and passwords to account numbers and PINs.
- The attacker can use this extracted information to gain access to some targeted system by simply logging in with the user's credentials.



COMMON NETWORK THREATS

Social Engineering Attack	Description
Pretexting	A threat actor pretends to need personal or financial data to confirm the identity of the recipient.
Phishing	A threat actor sends fraudulent email which is disguised as being from a legitimate, trusted source to trick the recipient into installing malware on their device, or to share personal or financial information.
Spear phishing	A threat actor creates a targeted phishing attack tailored for a specific individual or organization.
Spam	Also known as junk mail, this is unsolicited email which often contains harmful links, malware, or deceptive content.

COMMON NETWORK THREATS

Social Engineering Attack	Description
Something for Something	Sometimes called “Quid pro quo”, this is when a threat actor requests personal information from a party in exchange for something such as a gift.
Baiting	A threat actor leaves a malware infected flash drive in a public location. A victim finds the drive and unsuspectingly inserts it into their laptop, unintentionally installing malware.
Impersonation	In this type of attack, a threat actor pretends to be someone else to gain the trust of a victim.
Tailgating	This is where a threat actor quickly follows an authorized person into a secure location to gain access to a secure area.
Shoulder surfing	This is where a threat actor inconspicuously looks over someone’s shoulder to steal their passwords or other information.
Dumpster diving	This is where a threat actor rummages through trash bins to discover confidential documents.

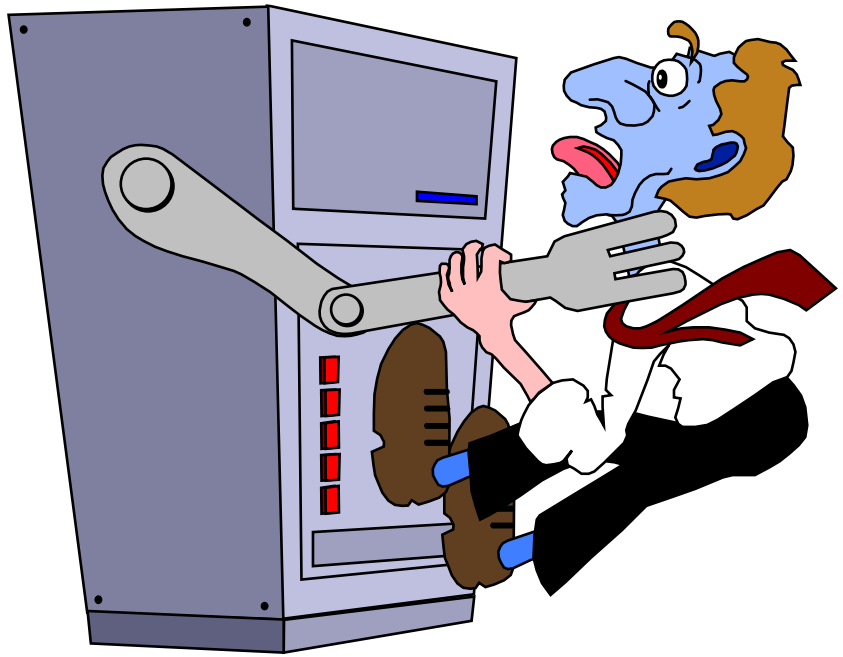
Acts of Human Error or Failure

- Includes acts done without malicious intent
- Caused by:
  - Inexperience
  - Improper training
  - Incorrect assumptions
  - Other circumstances
- Employees are greatest threats to information security – They are closest to the organizational data



Acts of Human Error or Failure

- Employee mistakes can easily lead to the following:
  - revelation of classified data
  - entry of erroneous data
  - accidental deletion or modification of data
  - storage of data in unprotected areas
  - failure to protect information
- Many of these threats can be prevented with controls



Protective Measures

1. **Bolster Access Control**
   - by using a strong password system.
   - You should have a mix of uppercase and lower case letters, numbers, and special characters.
   - Also, always reset all default passwords.
   - Finally, create a strong access control policy.
2. **Keep All Software Updated**
   - From anti-virus software to computer operating systems, ensure your software is updated.
   - When a new version of software is released, the version usually includes fixes for security vulnerabilities.
   - Manual software updates can be time-consuming. Use automatic software updates for as many programs as possible.

Protective Measures

3. **Standardize Software**
   - Keep your systems protecting by standardizing software like Operating system, Browser, Media player, Plug-in.
   - Ensure that users cannot install software onto the system without approval.
4. **Use Network Protection Measures**
   - Install a firewall
   - Ensure proper access controls
   - Use IDS/IPS to track potential packet floods
   - Use network segmentation
   - Use a virtual private network (VPN)
   - Conduct proper maintenance

Protective Measures

5. **Employee Training**
   - Sometimes external threats are successful because of an insider threat. The weakest link in data protection can be your own employees.
   - Ensure your employees understand network security.
   - Employees should be able to identify threats.
   - They should also know who to contact to avoid a security breach
6. **Schedule backups**
   - You can schedule backups to external hard drives or in the cloud in order to keep your data stored safely.
   - The right frequency is weekly but you can do incremental backups every few days.

Thank you !